

고객 Painpoint를 가치로 전환하는 상품화 개발 최적 방안

드론 AI 영상관제 플랫폼 GuardianX를 다중 지자체 상용 서비스로 만들기 위한 개발 우선 순위와 로드맵. Code가 운영 데이터 복제본에서 실측한 결과를 근거로 작성했습니다.

핵심 판단

지금 상품화의 병목은 "기능 부족"이 아니라
"신뢰의 증거 부족"이다. 신뢰를 먼저 봉인하고,
그 위에 고객 가치 기능을 얹는다.

왜 "신뢰 봉인"이 먼저인가

GuardianX는 이미 드론 영상 수집·AI 탐지·관제 화면·다지자체 계정까지 동작하는 제품입니다. 그런데 상용 계약으로 확장되지 못하는 이유가 이번 Code 실측에서 분명해졌습니다. 기능이 없어서가 아니라, **"우리 지자체 데이터가 남에게 안 보인다 / 24시간 안 죽는다 / 감사에 통과한다"**를 증거로 보여주지 못하기 때문입니다. 지자체 조달에서 이 세 가지는 협상 대상이 아니라 **입찰 자격**입니다.

§1 고객(지자체) Painpoint 지도

현장 담당 → 지자체장까지

PP-1 · 경보 피로

오탐이 너무 많다

AI가 바람·그림자·동물까지 알람을 울려 담당자가 알람을 꺼버리고, 정작 진짜 사건을 놓친다.

현재 GuardianX: 탐지는 하지만 "이 알람이 진짜였는지" 되짚어 볼 수단이 약함 → 오탐률이 숫자로 안 남음

PP-2 · 증거화 지연

사건 증거를 못 뺏는다

산불·불법투기 발생 시 상급기관·유관기관·법적 대응에 쓸 영상 클립·좌표·시각을 즉시 확보 못 함.

현재 GuardianX: 영상은 있으나 사건 단위 재검색·내보내기 흐름이 없음

PP-3 · 보고 부담

보고서에 몇 시간씩

담당자가 일일·상황 보고서를 수작업으로 작성. 감시가 아니라 문서작업에 시간을 쓴다.

현재 GuardianX: 데이터는 있으나 자동 취합·보고서 생성 없음

PP-4 · 역할 불일치

모두 같은 화면을 본다

담당자·부서장·지자체장이 필요한 정보가 다른데 화면은 하나. 아무도 자기 뷰가 없다.

현재 GuardianX: 단일 관제 화면 중심, 계층별 요약 없음

PP-5 · 운영 신뢰성

하나 죽으면 다 먹통

24시간 감시인데, 외부 스트리밍 서버 하나가 죽으면 목록 화면 전체가 멈춘다. 못 믿는다.

실측 확인: 외부 스트리밍 장애 시 목록 API가 **통째로 500** — 저하 운전 없음

PP-6 · 데이터 격리 (입찰 자격)

남의 지자체가 보인다

한 플랫폼에서 여러 지자체를 운영하는데 격리가 깨져 있음. Painpoint를 넘어 계약 파기·법적 리스크.

실측 확인: 한 계정이 남 테넌트 15~18건 열람, 드론 10대 교차 노출

PP-5-PP-6은 고객이 말로 요구하기 전에 조달·보안심사에서 자동 검증됩니다. 이 둘이 상품화의 진짜 관문입니다.

Code 실측이 드러낸 상품화 3대 리스크

아래는 추정이 아니라 Code가 운영 덤프 복제본 위에서 실제 테넌트·실제 사용자·실제 HTTP로 측정한 결과입니다. 합성 픽처보다 강한 증거이며, 세 가지 모두 상용 계약 전에 반드시 봉인해야 하는 P0입니다.

R1 테넌트 격리 붕괴

P0 · 입찰 자격

경로① — superuser 역할이 고객 테넌트 안에 배포돼 있음. 그 계정으로 목록을 열면 매니저가 의도적으로 필터를 건너뛰어 남 테넌트 15~18건이 그대로 보임. Fire_Drone은 자기 드론 11대 중 10대를 외부 2개 테넌트에 노출. 경로② — created_by IS NULL인 레코드는 superuser가 아닌 계정(anyang01)도 남 소유(Gaion) 건을 조회.

설계적 결론: 두 구멍 다 ORM 매니저(\$0.4 금지구역) 안에 있음. 매니저를 신뢰하는 어떤 설계도 이걸 못 막음 → W0-14 뷰 레벨 스코프가 유일한 차단 수단임이 실측으로 확정. 두 구멍은 독립적이라 각각 막아야 함.

R2 장애 전파 (저하 운전 부재)

P0 · 운영 신뢰

외부 스트리밍 서버가 죽으면 목록 API가 통째로 500으로 죽음. 스트리밍만 안 되고 목록·이력·통계는 살아 있어야 하는데, 하나의 외부 의존이 핵심 화면 전체를 끌어내림. 24시간 강제 제품에서 치명적.

봉인 방향: 외부 의존(스트리밍·AI·저장소)을 부분 실패 허용(graceful degradation)으로 격리 — 죽은 구성요소는 "일시 불가" 표시, 나머지는 정상 서빙.

R3 API-상태코드 계약 불일치

P0 · 감사·연동

권한 거부를 HTTP 200 body 안에 403으로 반환(보안 스캐너가 "성공"으로 읽어 감사 실패). 표준 POST /api/token/pair가 동작하지 않고 실제 경로는 /api/v1/auth/login(연동 문서와 불일치). delete-session은 body 호출 불가.

봉인 방향: 상태코드를 의미대로(403/401/500) 정정, 엔드포인트를 문서와 일치. 지자체 보안심사·타 시스템 연동의 전제.

전략적 합의 — R1~R3는 "버그 목록"이 아니라 상품화의 문턱입니다. 이 셋을 증거(테스트 출력·계측 로그)로 봉인하면, 그 증거 자체가 지자체에 파는 차별화 자산이 됩니다. 약점을 상품 특징으로 전환하는 것이 이 방안의 핵심입니다.

Painpoint → 기능 → 개발 순서

§2 가치 기능 매핑

U1~U4 · 고객 체감 가치

기능	내용	해결 Painpoint	고객이 얻는 것	참신성 포인트
U1	이벤트 증거화	PP-1 · PP-2	알람을 3클릭으로 재검색·증거 다운로드, 정탐/오탐 기록으로 오탐률을 수치화	"3클릭 증거화"
U2	보고 자동화	PP-3	사건·통계 자동 취합 → 보고서 생성. 주당 수 시간 → 10분	감시에 집중
U3	3계층 대시보드	PP-4	담당자(현장 대응) / 부서장(부서 KPI) / 지자체장(전역 요약) 각 뷰	역할별 관제
U4	격리·계측 상용봉인	PP-5 · PP-6	격리를 테스트 출력으로 봉인, 사용량을 시스템 집계로 → 안심하고 다시자체 판매	증거 기반 신뢰

§3 상품화 개발 로드맵

신뢰 봉인 먼저 → 가치 기능

1단계 신뢰 봉인 (Trust Sealing)

선행 · 필수 · ~6주

이것 없이는 다중 지자체 판매 불가. R1~R3를 테스트·계측 증거로 봉인. 신규 기능은 아직 만들지 않는다.

R1 격리 차단

W0-14 뷰 스코프 롤아웃(파일럿 1개 → 확대), 경로①·② 각각 차단, 466 라우트 HTTP 시험 green

R2 저하 운전

외부 의존 실패 격리, 죽은 구성요소만 "일시 불가", 나머지 정상 서빙

R3 계약 정합

상태코드 의미대로 정정, 엔드포인트 문서 일치, 연동 스펙 확정

환경 봉인

로컬 100% 기동 확정, 미검증 재고 1,217줄 전량 검증, 비밀·키 정합 (0건 유지)

2단계 가치 기능 (Customer Value)

봉인 후 · ~11주

봉인된 신뢰 위에 고객 체감 가치를 얹는다. 여기서부터 "팔리는 이유"를 만든다.

U1 이벤트 증거화

3클릭 재검색·증거 다운로드, 오탐률 지표화 (PP-1·2)

U2 보고 자동화

자동 취합·보고서 생성, 주당 N시간 → 10분 (PP-3)

U3 3계층 대시보드

담당자/부서장/지자체장 뷰 (PP-4)

U4 격리·계측 봉인 상품화

격리=테스트 출력, 요금=시스템 집계 (PP-5·6)

실기기(ONVIF·DJI) 검증과 실물 카메라는 보류 유지(D-226) — 파일럿/고객사 장비 시점으로 이월. 인프라 본체는 국내 클라우드 VM(CSAP 대응), Vercel은 홍보·랜딩 분담. 개발은 현재 PC(venv + Docker Postgres + Vite).

성공 측정 기준 & 대표 결정사항

§4 KPI — 편리성·완결성·안정성·참신성

모두 자동 측정 가능

● 편리성

- 증거 확보 클릭 수 ≤ 3 (U1)
- 보고서 생성 시간 ≤ 10분 (U2)
- 역할별 대시보드 도달 클릭 ≤ 2 (U3)

● 완결성

- 테넌트 격리 HTTP 시험 통과 466/466
- API 계약(상태코드·엔드포인트) 준수율 100%
- 미검증 재고 검증 완료율 100%

● 안정성

- 외부 의존 장애 시 핵심 기능 가용률 ≥ 99% (저하 운전)
- AI 알람 오탐률 추이 월 하락 (U1 기록 기반)
- 노출된 자격증명·키 0건 유지

● 참신성

- 3클릭 증거화 — 경쟁 대비 차별
- 3계층 역할별 관제
- 격리·계측 증거를 상품 자산으로 제공

§5 대표님이 결정하실 것

진행을 막고 있는 항목

P-LOCAL-5 superuser 역할을 회수할 것인가

최우선 · 진행 차단 중

superuser 역할이 전 테넌트를 보게 하는 것이 의도된 설계일 수 있음(운영 편의). 문제는 그 역할이 고객 테넌트 안 13개 실계정에 배포 있다는 것. 회수하면 그 13명 업무가 즉시 멈추고, 누가 왜 부여했는지 이력이 없음(reversible:false). 이 판정 없이는 W0-13(격리 마무리)이 못 나감. 권고: 회수 대신 "superuser 역할은 GAION 운영자 전용으로 분리, 고객 테넌트 계정에서 회수" — 단, 업무 중단 없도록 대체 권한을 먼저 부여 후 순차 전환.

D-보안 즉시 보안 조치 승인

① 노출된 자격증명 anyang / Admin@123 즉시 회전(채팅·공개 IP·평문 HTTP로 이미 노출). ② 운영 서버 HTTPS 적용 + 접근 IP 제한. ③ 서버 결제 계정 생존 확인(자산 소멸 시한). — 대표님 또는 신뢰할 운영자가 직접 수행, AI 브라우저 세션 경유 금지.

D-probe probe_guardianx 복제본 처리

Code가 격리 시험용 로컬 복제본 probe_guardianx에서 실사용자 9명의 비밀번호를 재설정함(운영본 database_guardianx는 무변경 확인, 운영 서버 미접속). 권고: 증거 파일 백업 확인 후 삭제 지시 — 실사용자 정보가 든 복제본을 오래 두지 않음.